

European Commission - Questions and answers



Partial Solution for the IoT insecurity problem



the Proposed solution by EU: preferred to have automatic updates even if they can cause problems (cost: downtime or breaking some device)

(for all the things that are connected to the Internet)

Cyber Resilience Act - Questions and Answers*

Brussels, 1 December 2023

Devices must be supported for at least 5 years
Vulnerabilities must be communicated and be fixed

What is the new EU Cyber Resilience Act?

The Cyber Resilience Act is the first ever EU-wide legislation of its kind. It introduces common cybersecurity rules for manufacturers and developers of products with digital elements, covering both hardware and software.

The Cyber Resilience Act will ensure that:

- Wired and wireless products that are connected to the internet, and software placed on the EU market are more secure;
- Manufacturers remain responsible for the cybersecurity of a product throughout its lifecycle;
- Consumers are properly informed about the cybersecurity of the products they buy and use.

What kind of risks does the proposal aim to address?

Cyber-attacks can spread across borders in the internal market within minutes. The regulation therefore tackles two issues.

- 1 The first is the low level of cybersecurity of many of these products and more importantly the fact that many manufacturers do not provide updates to address vulnerabilities.

While manufacturers of products with digital elements sometimes face reputational damage when their products lack security, the cost of vulnerabilities is predominantly borne by professional users and consumers. This limits the incentives of manufacturers to invest in secure design and development and to provide security updates.

- 2 The second is that businesses and consumers often do not have sufficient and accurate information when it comes to choosing products that are secure. And they often lack knowledge of how to make sure that the products they buy are set up in a way that is secure.

The new rules tackle these two aspects by addressing the issue of updates and the issue of providing up to date information to customers.

How does the Cyber Resilience Act address these problems?

The Cyber Resilience Act establishes that products with digital elements will only be made available on the market if they meet specific essential cybersecurity requirements. It requires manufacturers to factor cybersecurity into the design and development of products with digital elements.

Regarding the information and instructions provided to the end user, the Cyber Resilience Act requires manufacturers to be transparent on cybersecurity aspects that need to be made known to customers.

A key element of the proposal is the coverage of the whole lifecycle of the products, and in particular the provision of obligations for manufacturers and developers to define a support period that reflects the time the product is expected to be in use, and to provide security updates during that period.

Such obligations would be established for economic operators, starting from manufacturers, up to distributors and importers, in relation to the placing on the market of products with digital elements, as adequate for their role and responsibilities on the supply chain.

Based on the New Legislative Framework for product legislation in the EU, manufacturers would undergo a process of conformity assessment to demonstrate whether the specified requirements relating to a product have been fulfilled.

This could be done via self-assessment or a third-party conformity assessment, depending on the level of risk associated with the product in question.

Where compliance of the product with the applicable requirements has been demonstrated, manufacturers and developers would draw up an EU declaration of conformity and will be able to affix the CE marking. The CE marking will indicate the conformity of products with digital elements with the Cyber Resilience Act, so that they can move freely within the internal market.

Who will benefit from the Cyber Resilience Act?

The Cyber Resilience Act will bring significant benefits to the various stakeholders. Businesses will soon have to comply with only one single set of cybersecurity rules across the EU.

The Act will reduce the number of cybersecurity incidents and with this, the cost of incident handling and reputational damage for companies. As such, it would increase trust consumers and business customers have in companies and products, and so increase the demand for products with digital elements, both within and outside the EU.

At the same time, consumers and users will benefit from more information when choosing a product with digital elements and from clearer instructions about its use. As a result of fewer security risks and incidents, consumers and citizens will benefit from better protection of fundamental rights, such as data protection and privacy protection.

The Cyber Resilience Act also has the potential to become an international point of reference beyond the EU's internal market. EU standards based on the Act will facilitate its implementation and will be an asset for EU manufacturers in global markets.

What will happen to non-compliant products?

Member States will appoint market surveillance authorities, which would be responsible for the enforcement of the Cyber Resilience Act obligations.

In case of non-compliance, market surveillance authorities could require operators to bring the non-compliance to an end and eliminate the risk, to prohibit or restrict the making available of a product on the market, or to order that the product is withdrawn or recalled. Each of these authorities will be able to fine companies that do not adhere to the rules. The Cyber Resilience Act establishes maximum levels for administrative fines, which should be provided for in national laws in cases of non-compliance.

Will software, when provided as a service and not as a product, be covered under the CRA?

Software provided as part of a service is not covered by the proposed Cyber Resilience Act, as it covers only products with digital elements that are sold within the European single market, and sets out concrete cybersecurity requirements and obligations for the manufacturers of these products. However, the Directive on measures for a high common level of cybersecurity across the Union ([NIS 2 Directive](#)), and other sectorial legislation, ensure that systems provided as a service or developed in-house meet equivalent technical requirements for cybersecurity. This could be the case, for example, for electronic health record (EHR) systems. They should also provide the same level of protection against cyber threats as products with digital elements covered by the Cyber Resilience Act.

Under the NIS 2 Directive, Member States are requested to ensure that essential and important entities, such as healthcare or cloud providers and public administration entities, take appropriate and proportionate technical, operational and organisational cybersecurity measures. This includes, among other things, a requirement to ensure security in network and information systems acquisition, development and maintenance, including vulnerability handling and disclosure.

Technical and methodological requirements for certain types of entities, such as cloud computing service providers, as well as sectoral requirements, if needed, will be defined through implementing decisions.

How will it interplay with the existing rules?

The Cyber Resilience Act will ^{standardize} harmonise the EU regulatory landscape by introducing cybersecurity requirements for products with digital elements and avoid overlapping requirements stemming from different pieces of legislation. This will create greater legal certainty for operators and users across the Union, as well as a better harmonisation of the European single market, creating more viable

Prima di questa legge, le regole potevano variare tra i diversi stati membri o tra diversi settori. Ora, chiunque voglia vendere un prodotto digitale nell'UE deve seguire lo stesso set di regole. Questo evita che le aziende debbano decifrare un puzzle di leggi diverse (il cosiddetto "overlapping").

conditions for operators aiming to enter the EU market.

NIS2 Directive

In particular, the Cyber Resilience Act will complement the NIS2 Directive, which was recently agreed by the European Parliament and the Council. The NIS2 Directive puts in place cybersecurity requirements, including supply chain security measures and incident reporting obligations for essential and important entities, with a view to increasing the resilience of the services they provide.

Therefore, the enhanced level of cybersecurity of products with digital elements would facilitate compliance by the entities in the scope of the NIS2 Directive and would strengthen the security of the entire supply chain.

Delegated Regulation under the Radio Equipment Directive

The Cyber Resilience Act applies to radio equipment in scope of the [Delegated Regulation adopted under the Radio Equipment Directive 2014/53/EU](#) (RED Delegated Regulation). The Cyber Resilience Act is aligned with the requirements of the RED Delegated Regulation, including the specific requested standards under the RED Delegated Regulation.

The Cyber Resilience Act thus constitutes the next important all-encompassing step, which builds on these standards under development until the Cyber Resilience Act becomes applicable. To ensure legal clarity, the RED Delegated Regulation will therefore be ^{modified} ~~amended~~ or ^{canceled} repealed.

What are the next steps?

Once the proposal is formally adopted and enters into force in 2024, economic operators and Member States will have 36 months to adapt to the new requirements.

An exception to this rule is the reporting obligation on manufacturers for actively exploited vulnerabilities and incidents, which would apply 21 months from the entry into force, since they require fewer organisational adjustments than the other new obligations.

To make it easier for manufacturers – in particular for those that build important products – to apply the essential requirements, the Commission will issue a standardisation request, allowing the European Standardisation Organisations to develop technical standards for many of the product categories covered by the Cyber Resilience Act.

The Commission will periodically review the Cyber Resilience Act and report on its functioning.

**Updated on 01/12/2023*

QANDA/22/5375

Press contacts:

[Johannes BAHRKE](#) (+32 2 295 86 15)

[Roberta VERBANAC](#) (+32 2 29 82498)

General public inquiries: [Europe Direct](#) by phone [00 800 67 89 10 11](#) or by [email](#)